XITA Direct-BLS: Corrected Production-Readiness Assessment

Audit ID: XITA-DBLS-2026-10-27-v3.1.0
Revision: r1, 27 October 2026
Auditor: OpenAI GPT-6 Astra - AI-assisted independent security assessment
Document type: Correction supplement to the delta assessment; not a new clean-slate audit.

1. Executive decision

Decision: CONDITIONAL GO for the explicitly restricted, self-funded core transfer scope below. This is not an unrestricted GO and does not approve unattended gas sponsorship.

The earlier blanket NO-GO rationale based on an allegedly undocumented or wholly unsupported Mainnet activation is withdrawn. The canonical public Mainnet configuration explicitly schedules `securityAccounting` at block **12,186,213**, inclusive. Retained audit observations already show v3.4.0 at two public XGR RPC URLs, and agreement across 19 sampled block heights surrounding the reported fork and epoch boundaries. The native corrections were independently exercised during the original delta work and are included in the published v3.4.0 release. These distinct evidence layers must be considered together. [E1-E4]

A missing per-validator host attestation is an assurance limitation; it is not, by itself, evidence that the correction is absent, inactive or exploitable in production. Equally, a version string, published genesis and matching ordinary blocks are not a cryptographic proof of every host's effective configuration. The correction therefore records **corroborated deployment with an explicit configuration-conformity assumption**, rather than claiming complete host-level verification. The operator's statement that the PoS validators were upgraded remains identified as an operator statement. [E1-E5]

The restricted assessment covers self-funded principal transfers on the already assessed XGRChain, Base and Arbitrum routes, with supported externally owned native recipients and the operating controls in section 7. The optional sponsor is excluded from this approval until its existing obligations, nonce recovery and monitoring weaknesses are controlled. No risk is accepted on the operator's behalf; the conditions are prerequisites, not assertions that every control has been installed.

This supplement changes the deployment rationale and scoped release recommendation. It does not rewrite the immutable Phase A analysis, erase historical findings, claim new test executions, or replace the preserved v3.0.0 baseline report. The previously prepared full v3.1.0 draft and its complete publication package were not merged. This publication contains the correction report and its supporting evidence, not a claim that the earlier 90-page draft and all 337 proposed evidence files have been archived.

2. Scope, revisions and authority

The application source baselines remain unchanged:

- Interchain: `xgr-network/xgr-interchain`, `26d1356ce7c92eed67bfdbb91a5a0b19efc25ae3`.
- Node: `xgr-network/xgr-node`, `51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671`.
- Published node release: v3.4.0, commit `cbe6f8a4ae1718429a9924dcf87f0d28591d74e1`.
- Additional operator-supplied configuration authority: `xgr-network/XGR`, revision `70af62db9fe9c197e2e755dae7919baf313a13ca`, `genesis/mainnet/genesis.json`.

The public XGR repository is used only for the specifically supplied canonical network configuration and release documentation. This does not silently extend the application-code audit to another implementation. Historical v3.0.0 files remain unchanged.

The original Phase A master has SHA-256 `f969196c28a26357a05c98fcd14018bbd3381af99684f7dc900af2851b1cf08e`. That commitment was checked against the recovered access-controlled master during this correction. No Phase A text was retrospectively modified. The restricted archive is referenced separately and is not published. [E6]

3. Correction record and evidence limits

C-01: Canonical fork schedule was omitted from the release rationale

The pinned public genesis has chain ID `1643` and `params.forks.securityAccounting.block = 12186213`. The file's Git blob is `582e5a3631655bcb68cbc87568f3c04901dfe366`; the schedule was added by commit `f94f71a4429473754c17edcf993efda8ca08b575`. This is independently read repository configuration, not merely a statement in chat. The accompanying v3.4.0 activation documentation describes the same inclusive height. [E1]

This establishes the published canonical schedule. It does not show a file read from each validator's disk. The operator reports that participating PoS validators use the upgraded implementation and this schedule. For the restricted decision, configuration conformity is an explicit operational assumption with an immediate re-evaluation trigger if conflicting configuration or execution evidence appears.

C-02: Existing RPC evidence must not be discarded

The retained original audit responses are exact successful `web3_clientVersion` observations:

- `https://rpc.xgr.network`, 2026-10-27 15:33:59 UTC: `xgrchain/v3.4.0/linux-amd64/go1.23.11`.
- `https://rpc1.xgr.network`, 2026-10-27 15:34:00 UTC: the same version string.

Both also returned Mainnet chain ID `0x66b`. These are **two URLs**, not a claim of independent upstream ownership or proof that each represents a different validator. [E2]

The operator additionally supplied `rpc2.xgr.network`. No successful rpc2 version response is present in the retained input examined for this supplement. Fresh direct RPC requests were unavailable because the correction environment could not resolve the endpoints. This is an audit-environment limitation, not a finding that the nodes are down. The previous conversational statement that both rpc1 and rpc2 had already been independently verified is corrected: the recoverable observations are rpc and rpc1.

C-03: Continuity corroborates rollout but does not prove all rejection rules

The retained audit compared 19 distinct heights using rpc and rpc1. Core block fields agreed at all 19, including block hash, parent, state root, receipt root and gas. H-1, H and H+1 are represented. Adjacent epoch-marker receipts were also inspected in the original native track. [E3]

The sampled blocks are empty or contain the already-supported canonical epoch marker. Such accepted blocks can be compatible with both historical and activated rules. Their consistency is positive evidence of continuity, not a distinguishing experiment proving rejection of every forbidden StateTx or activation of transaction-dependent SSTORE semantics. That technical limitation in the earlier native analysis remains valid; only the overbroad release consequence is corrected.

A new read-only Mainnet MCP observation during preparation returned block **12,194,361**, chain ID 1643, beyond H. It confirms continued head progression at that observation, not a complete independent replay. [E5]

C-04: Release identity and installed identity remain separate

The verified published Linux AMD64 artifact has SHA-256 `c4b41557ee957f1a1e6487aa7701ae593ae2e657a911a4761627f728a61be85e`. Original delta evidence verifies the downloaded artifact and manifests, the release ancestry and identity of relevant implementation blobs. Release-to-audit-head changes in that record are documentation only. [E4]

The release artifact reports Go 1.23.12, while the observed RPC version strings report Go 1.23.11. Consequently the RPCs cannot be declared byte-identical to that particular release artifact. An equivalent-source local build is possible; a different toolchain string alone is not evidence of missing fixes. No installed disk hash, complete host configuration inventory or reproducible-build proof is claimed.

4. Native corrections: F-01 and F-02

F-01: VERIFIED in the frozen source; included in the published release. Historical severity High is preserved. No unresolved High is inferred solely from missing host attestations.

The retained independent native assessment traces authorization through proposal validation and finalized-block execution. Under the explicit fork, executable StateTx transactions are rejected outside the permitted canonical marker path. The marker is restricted by epoch and block-body rules. Non-fee-bearing system transactions receive no ordinary gas credit without an upfront debit. Parent-derived BaseFee checks fail closed on tested unreadable state and reject incorrect fee values at the relevant consensus boundaries. [E4, E7]

F-02: VERIFIED in the frozen source; included in the published release. Historical severity Medium is preserved.

The original independent matrix exercises transaction-local storage originals, nested delegate calls and reversions, signed transactions and actual trie commits. Active execution matched a fresh committed-state reference in the recorded 972-case matrix. Forty-eight finite preactivation differential vectors matched historical execution. These are meaningful isolated execution checks, not a claim to have replayed every Mainnet block or tested every possible EVM program. [E7]

Retained test records separately report 1,081 passing native test/subtest events across three packages, 479 passing existing test/subtest events across eight packages, and one passing four-process validator fork-boundary E2E. The four-validator test checks a generated local fork schedule, not the installed production genesis. These counts are not added into a misleading count of unique independent attack scenarios. They were executed during the original delta work, not rerun during this correction. [E7]

Production status for both findings is **corroborated, not individually host-attested**. The conditional core recommendation assumes participating validators implement the verified rules with the canonical schedule. Evidence of a nonconforming quorum, incompatible roots or an actual accounting bypass immediately invalidates that recommendation. The source disposition is not changed to RELEASED merely because a tag or version string exists.

5. Direct-BLS and historical H-01 / F-05

F-05 remains **Medium residual risk**. The retained assessment distinguishes native locally committed XGR evidence from external Base/Arbitrum RPC witnesses. External authorization requires complete matching evidence from two differently labelled operators. Duplicate labels and one surviving operator do not satisfy that requirement; a later matching pair can succeed even after an earlier disagreement. Operator labels alone do not prove infrastructure independence. [P1, E6]

Two correlated providers can still give otherwise honest signers a matching false view. L2 safe finality is also not the same as final Ethereum settlement. These are explicit remaining assumptions, not a demonstrated BLS break. This correction neither restores the obsolete single-provider High classification nor labels provider correlation fixed. Maintain genuinely independent providers, monitor disagreement and fail closed when the required qualified evidence is absent.

Optional indexing, relaying, sponsorship and UI services do not create cryptographic transfer authority. Accordingly, sponsorship availability or monitoring defects are not automatically evidence of unsafe principal minting. Principal accounting, recipient eligibility, signer quorum and exact deployed bindings remain

necessary conditions for the supported core paths. Membership signatures and message signatures have distinct domain-binding properties and must not be conflated. [P1]

6. Sponsorship and remaining findings

The retained delta records verify the restricted quote-writer correction (F-06) using actual isolated PostgreSQL roles and the background route-scheduling correction (F-26). F-27's release-metadata defect is addressed in the verified v3.4.0 artifact. They do not prove production database migration or installed service state. [E4, E7]

F-07 and F-19 remain open: interrupted or externally advanced transfers can leave paid sponsorship obligations and reserved nonces unresolved. Read-only liability diagnostics do not settle them. F-08 has a partial submitted-grant isolation correction, but earlier whole-sweep RPC work can still obstruct unrelated chains. Disabling new promises must not erase or silently abandon existing obligations. [P1, E7]

The retained delta records also identify F-30 (Medium): reconciliation can refresh the age used by delayed-grant monitoring, suppressing a delayed-obligation signal. F-31 (Low) concerns failed-receipt presentation. The protocol Phase A record identifies a separate Medium resource-lifecycle issue, assigned F-32 in this correction register: unverified route-request storage is not fully bounded by discovery-hint expiry. Public descriptions intentionally omit reproduction payloads and exploit steps. [E6]

Unattended sponsorship is not approved by this supplement. A restricted self-funded core launch is separable only when no new sponsor promise is made to those users, owed commitments remain visible, and the operator maintains a controlled reconciliation process. This report does not assert that the production inventory is empty or that a configuration switch has been changed.

The compact `findings.csv` records 32 current identifiers, with five source/release corrections (F-01, F-02, F-06, F-26, F-27) separated from the residual inventory: **0 Critical, 0 High, 16 Medium, 10 Low, 1 Informational**. This is an issue register, not a probability or loss estimate. Original severity and titles are retained where available; shortened residual summaries refer to the immutable predecessor register and the protected delta records for full technical detail. The correction does not claim a fresh independent reassessment of every unchanged finding.

7. Enforceable conditions for the restricted decision

G1 - Consensus configuration conformity

Owner: validator operators, coordinated by the network operator. Participating validators must execute release-equivalent corrected code using the canonical inclusive height 12,186,213. Preserve configuration/build records and monitor canonical root agreement. Do not revise a past fork height or roll back execution rules. Re-evaluate immediately on conflicting roots, source/build mismatch, incorrect native accounting or a nonconforming voting quorum. Present evidence: verified source/release, published genesis, operator rollout statement and corroborating RPC/chain observations. Per-host verification remains outside the completed evidence.

G2 - Restricted transfer product

Owner: XITA service operator. Support only already assessed route bindings on XGRChain, Base and Arbitrum. Do not extend this approval to new chains, arbitrary new token behaviors, overlapping registry deployments or unassessed upgrades. Native recipients must be supported ordinary EOAs without recipient code/delegated execution; do not assume every address described by a wallet as an EOA is code-free. F-09's backed deferred-claim path is not solved by inventing an additional user signature or claim transaction. Check recipient eligibility and disclose unsupported recipients before initiation.

G3 - Sponsorship separation and existing obligations

Owner: sponsor service and treasury operator. Make no new sponsorship commitments within the approved self-funded product. Preserve all existing commitments, grant records, transaction identity and nonce ownership. Review obligations using immutable creation/submission/progress evidence and persistent errors, not solely a clean age-based F-30 diagnostic. Investigate ambiguous outcomes before any retry or settlement; never delete reservations to recover capacity or broadcast a different uncertain payment. Re-enable sponsored journeys only after documented obligation handling and representative paid-path verification.

G4 - Availability containment and recovery

Owner: node/RPC operators and XITA operations. Apply bounded access/rate/concurrency limits to resource-intensive public request paths, preserve independent consensus capacity, monitor disk/inodes and oldest unresolved work, and retain source transaction identifiers for recovery. Limit supported load and route expansion until F-03/F-04/F-20/F-21/F-29/F-32 have adequate controls. Governance and membership maintenance must be coordinated rather than allowed to jeopardize message quorum. A backlog, persistent resource growth or stalled shutdown triggers restriction of new managed admissions and investigation, without deleting authenticated unsettled evidence.

G5 - Quorum, witnesses and ownership

Owner: validator and deployment operators. Maintain the assessed minimum committee and threshold, independent key custody and a single active registry per chain. Preserve complete two-operator external evidence checks and the adopted finality policy. Review actual upstream correlation; distinct URLs alone do not qualify. Coordinate membership/key changes before loss of the recoverable signing quorum. Changes in providers, committee concentration, registry migration or deployed bindings require reassessment.

These are scoped prerequisites. This correction has not independently inspected the operator's installation of every access control, obligation process or recipient restriction. The report is not an unconditional claim that the current production product satisfies them.

8. Component conclusions and path to unrestricted GO

Core Direct-BLS/principal transfers and permissionless one-/two-hop execution receive a **conditional recommendation within G1-G5**, not a protocol-wide guarantee. Native consensus corrections are independently verified in source and release; deployment is operationally corroborated with the stated conformity assumption. Optional sponsorship and unrestricted recovery/observability remain outside unrestricted approval.

Unrestricted GO requires evidence that the applicable controls are actually operating; safe resolution or durable containment of paid sponsor commitments; reliable age/error monitoring; representative paid and self-funded journeys with supported recipient behavior; and closure or explicitly owned, technically bounded acceptance of the remaining material availability/recovery risks. No blanket redesign, new bridge deployment or extra user signing step is mandated merely to remove every Low or Medium item.

A new Critical/High principal-safety defect, contradictory activation evidence or failed quorum/accounting invariant requires a new release decision. A documentation correction cannot repair such a defect and this report would not conceal it.

9. Evidence, provenance and publication

[E1] `evidence/canonical-genesis-evidence.json`: pinned public XGR genesis, blob identity and schedule. Official document: https://github.com/xgr-network/XGR/blob/70af62db9fe9c197e2e755dae7919baf313a13ca/docs/chain/XGRCHAIN_v3.4.0_Release_and_Activation.md

[E2] `evidence/rpc-version-observations.json`: retained original successful Mainnet RPC responses and exact observation timestamps; rpc2 limitation.

[E3] `evidence/fork-boundary-parity.json`: recomputed parity summary and selected H-1/H/H+1/epoch observations; commitment to the retained source record.

[E4] `evidence/release-provenance.json`: original release-download verification, checksum, source ancestry and relevant implementation-blob equivalence.

[E5] `evidence/current-chain-status.json`: new read-only MCP head observation during correction preparation.

[E6] `evidence/original-phase-a-commitment.json` and `confidential-evidence-reference.json`: unchanged independent Phase A and protected evidence identity. Exact unrepaired reproduction material is not public.

[E7] `evidence/retained-test-results.json`: original native and services test totals, commands, timestamps and explicit limitations. No fresh test execution is implied.

[P1] Immutable predecessor report and complete original finding/historical registers: https://github.com/xgr-network/xgr-interchain/tree/26d1356ce7c92eed67bfdbb91a5a0b19efc25ae3/audits/2026-10-27-xita-direct-bls-final-v3.0.0

The public evidence ZIP contains only allow-listed, non-sensitive observations and summaries. The archive manifest records actual prepared PDF, Markdown and evidence bytes. `pdf-validation.json` records rendering and consistency checks. Publication verification must distinguish exact-byte retrieval from Git object metadata; metadata alone is not claimed to be a downloaded-byte comparison. No application code, production configuration, database state or on-chain transaction is changed by this publication.